

The EU Cloud Code of Conduct (abbr. "EU Cloud CoC" also known by its extended title "EU Data Protection Code of Conduct for Cloud Service Providers") is a transnational Code of Conduct pursuant Article 40 of the European General Data Protection Regulation (GDPR).

The code defines clear requirements for cloud service providers (CSPs) to implement Article 28 GDPR and all its related articles, which covers the processing activities of every type of personal data.

Encompassing all cloud service layers (including but not limited to IaaS, PaaS, and SaaS), the code allows cloud service providers to demonstrate GDPR compliance in their role as processors, which is overseen by an accredited monitoring body, as required by Article 41 GDPR.

History

The work on the code started in 2012 when former vice president of the European Commission, Neelie Kroes, launched the European Cloud Strategy. In that context, a dedicated working group was created with the task to draft a cloud code of conduct under the Data Protection Directive.

One of the primary goals of drafting such code was to increase trust and amplify the adoption of cloud computing across the European Union. The first draft produced by the working group was submitted to its first assessment in January 2015, which was then performed by the Article 29 Working Party.

With the introduction of the GDPR, the code had to be adapted accordingly and by 2017, the European Commission fully handed over the project to the industry.

Still in 2017, six companies coming from that working group (Alibaba Cloud, Fabasoft, IBM, Oracle, Salesforce and SAP) founded the EU Cloud CoC General Assembly and assigned SCOPE Europe as its monitoring body and secretariat.

After several exchanges with supervisory authorities and related revisions, the final version of

the EU Cloud CoC was submitted to the Belgian Data Protection Authority for approval in 2019. According to the timestamps of the code versions published on the initiative's website, the code evolved further after submission and until its approval in May 2021. Such continued development of codes of conduct is expected, following the European Data Protection Board's Guidelines 1/2019 on codes of conduct and monitoring bodies under Regulation 2016/679. The code has been approved by the Belgian Data Protection Authority as of May 20, 2021, following a positive opinion issued by the European Data Protection Board.

Scope and structure of the code

The EU Cloud CoC allows CSPs to prove and demonstrate compliance within the scope of Article 28 GDPR and all its related Articles. Therefore, the EU Cloud CoC comprehends CSPs data protection obligations when processing any kind of personal data and its requirements are applicable to all cloud offerings (including but not limited to IaaS, PaaS, SaaS).

There are five sections that together compose the core structure of the code, namely, Scope, Data Protection, Security Requirements, Monitoring and Compliance and Internal Governance. Besides the main text, the code is accompanied by a controls catalogue, which was designed to map the code's requirements to auditable elements, the "Controls", and to all corresponding GDPR provisions. Additionally, the controls catalogue also provides a mapping to relevant international standards (such as ISO 27001, ISO 27017, SOC 2 and BSI C5).

Organizational structure

The organizational structure of the EU Cloud CoC is covered under its Internal Governance Section, which describes the rules and procedures applied for the code's management. The referred Section lays out the organizational framework of the code itself, as well as of its bodies, namely, the General Assembly, the Steering Board, and the Secretariat.

Dedicated monitoring body

The GDPR requires an independent monitoring body to guarantee the appropriate implementation of its provisions.

In May 2021, SCOPE Europe has been officially accredited by the Belgian Data Protection Authority as the dedicated monitoring body of the EU Cloud CoC.

According to GDPR, the monitoring body shall be responsible for performing an ongoing due diligence. Under the EU Cloud CoC, besides being subjected to an initial assessment to become adherent to the code, CSPs are reevaluated on an annual basis.

Additional assessments can also be triggered by justified complaints, media reports, new legislations, publications and Guidelines from Data Protection Authorities and any other relevant development that can potentially affect adherence to the code.

A CSP can opt for three Levels of Compliance once declaring adherence to the EU Cloud CoC. Those levels relate solely to the type of evidence that is subjected to the review of the monitoring body. Nevertheless, each of those levels demands compliance to all the code's requirements.

Membership and supporters

Membership to the code is open to any CSP as long as they agree with the approach and principles established in the code. In that regard, the EU Cloud CoC offers two main membership options, the first being dedicated to CSPs and the second covering any entity that is not a CSP and wishes to join the initiative as supporter.

Within the CSP membership umbrella, a tailored pricing scheme is in place, which takes into consideration the needs of different company sizes allowing for accessibility for Small and Medium Enterprises (SMEs).

Today, the EU Cloud CoC General Assembly represents a significant share of the European cloud industry market and, as of August 2021, its membership encompasses Alibaba Cloud,

Alight, Arcules, Cisco, Dropbox, Epignosis, Fabasoft, Google Cloud, IBM, K&L Gates, Microsoft, Okta, Oracle, Qompium (Extra Horizon), Salesforce, SAP, Schellman, SecureAppbox, Timelex, TrustArc and Workday.

The third country transfer initiative

Following the CJEU's Schrems II ruling, the EU Cloud CoC General Assembly started to work on an effective and yet accessible safeguard for third country transfers in the format of an on-top module to the code.

The so-called Third Country Transfer Module shall cover the legal requirements for third country transfers as outlined in Chapter V GDPR and, as any on-top module is not a standalone initiative which implies that prior compliance with EU Cloud CoC is a pre-requisite.

See also

EU Cloud CoC's website

List of adherent Cloud Services, including public reports

Monitoring Body of the EU Cloud CoC

== References ==